

# Incident Report: SOAR-0006

AICS-112 Lab 7 capstone | Pipeline v1.1.0, playbook v1.1.0 | Prepared by Firdaws Alnuur Mohammed | All data synthetic; all actions dry-run

## Executive summary

A finance-operations user, fatima.sani, received a phishing email on 26 August 2026 and within about 50 minutes her account was taken over from Ghana, an unverified OAuth app was granted mailbox access, her workstation OPS-WS-009 ran encoded PowerShell and beacons out, and 96 MB left the network to flagged infrastructure. The pipeline scored this 97/100 (critical).

Status: partially contained, in simulation only. The analyst Firdaws Alnuur approved isolation of OPS-WS-009 and denied the other two high-impact actions (disable fatima.sani and revoke the MailSync Pro OAuth grant) to exercise the deny path. In the scenario the account and the OAuth grant therefore remain active. Decision required: approve the disable and the revoke, then reset credentials and review what the 96 MB contained.

## Scope and confidence

- Users: fatima.sani. Asset: OPS-WS-009. Window: 06:58 to 07:48 UTC (07:58 to 08:48 WAT) on 2026-08-26.
- Sources: email, proxy, identity, endpoint, network (5 of 5 relevant sources, 9 correlated events).
- Confidence: high that this is a real compromise, because five independent sources agree and three indicators (IP, domain and file hash) match threat intel. Medium on what was exfiltrated: we know the size and destination, not the content.
- Gaps: no mailbox audit log (what MailSync Pro read), no proxy content inspection, and the capstone has no ground truth, so no precision or recall can be claimed.

## Timeline

Times are UTC / WAT (UTC+1). Event IDs are from the capstone dataset.

| UTC / WAT     | Event  | Observation                                                                 | Interpretation                                                                                     | Action                                                   |
|---------------|--------|-----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| 06:58 / 07:58 | CP-001 | Remittance notice delivered from external sender (secure-docs-auth.example) | Likely phishing lure; domain matches threat intel                                                  | Case opened                                              |
| 07:02 / 08:02 | CP-002 | User clicked the external authentication link                               | Credential-harvest page visited                                                                    | Case opened                                              |
| 07:09 / 08:09 | CP-003 | Sign-in failure from 198.51.100.44 (GH)                                     | Attacker testing stolen credentials                                                                | Analyst notified                                         |
| 07:11 / 08:11 | CP-004 | Sign-in success from GH; user normally signs in from NG                     | Account takeover (impossible-geography login)                                                      | Analyst notified                                         |
| 07:16 / 08:16 | CP-005 | Consent granted to unverified app "MailSync Pro"                            | Persistence through OAuth grant; survives a password reset                                         | revoke_oauth_grant denied by analyst (test of deny path) |
| 07:31 / 08:31 | CP-006 | Encoded PowerShell launched from a spreadsheet process on OPS-WS-009        | Likely malicious macro execution (inferred from parent process); payload hash matches threat intel | isolate_endpoint approved by analyst (simulated)         |
| 07:34 / 08:34 | CP-007 | TLS beacon every 60 s to 203.0.113.77                                       | Command-and-control channel                                                                        | Triage collected                                         |
| 07:41 /       | CP-008 | Browser credential store access                                             | Credential theft attempt stopped                                                                   | None needed                                              |

| UTC / WAT     | Event  | Observation                           | Interpretation             | Action                                                 |
|---------------|--------|---------------------------------------|----------------------------|--------------------------------------------------------|
| 08:41         |        | attempt, blocked                      | by endpoint control        |                                                        |
| 07:48 / 08:48 | CP-009 | 96 MB upload to 203.0.113.77, allowed | Probable data exfiltration | disable_identity denied by analyst (test of deny path) |

## Technical findings

- IOC matches: IP 198.51.100.44, domain secure-docs-auth.example and the PowerShell file hash 9d6f8f67... are inside their STIX valid\_from/valid\_until windows at event time (the v1.1.0 validity check).
- Score drivers (model probability 0.997): ioc\_match, multi\_source, malware\_signal, identity\_anomaly, exfil\_signal. critical\_asset and privileged\_identity were 0, so the score comes from the attack chain, not from who the user is.
- Shared infrastructure: the same IP 198.51.100.44 was used in the password spray against wale.admin (SOAR-0005). The pipeline did not link the two incidents. This is probably one campaign and is the main correlation gap.
- AI assist: advisory only. It was not used to approve or run any action; every decision below was made by the named human analyst.

## ATT&CK mapping

| Technique                                          | Evidence       | Uncertainty                                                |
|----------------------------------------------------|----------------|------------------------------------------------------------|
| T1566 Phishing                                     | CP-001, CP-002 | Link vs attachment delivery not confirmed                  |
| T1078 Valid Accounts                               | CP-003, CP-004 | Credentials were presumably phished; not directly observed |
| T1528 Steal Application Access Token (OAuth abuse) | CP-005         | Scope of permissions granted is unknown                    |
| T1059.001 PowerShell                               | CP-006         | Macro origin inferred from parent process                  |
| T1071 Application Layer Protocol (C2)              | CP-007         | Beacon interval is strong evidence; payload unseen         |
| T1555.003 Credentials from Web Browsers            | CP-008         | Blocked, so no confirmed theft                             |
| T1041 Exfiltration Over C2 Channel                 | CP-009         | Content of the 96 MB unknown                               |

## Containment and approval

- Automatic, no approval: create\_case, notify\_analyst, collect\_endpoint\_triage (all dry-run).
- Approval-gated (named human required): isolate\_endpoint (endpoint evidence present), disable\_identity (score 85 or above), revoke\_oauth\_grant (oauth\_consent event present).
- Approver: Firdaws Alnuur, via the operations console, 2026-10-02. isolate\_endpoint: approved (simulated), 13:24:45 UTC / 14:24:45 WAT. disable\_identity: denied, 13:24:56 UTC / 14:24:56 WAT. revoke\_oauth\_grant: denied, 13:25:04 UTC / 14:25:04 WAT. The two denials were made deliberately to test the deny path and confirm that a denied action is logged and not executed. They are not a judgement that the actions are unnecessary.
- Residual risk: with the disable and the revoke denied, fatima.sani stays active and MailSync Pro keeps mailbox access, and an OAuth grant survives a password reset. In a real incident I would approve both, because the account takeover (CP-004) and the OAuth consent (CP-005) are

confirmed by independent sources and waiting only extends attacker access. The cost of acting is low and reversible: re-enable the account or re-grant the app if this proves a false positive.

- Every action ran with dry\_run on; no real account or endpoint was changed. The audit hash chain verified OK.

## **Eradication and recovery**

- Done in simulation: OPS-WS-009 isolated. Still outstanding because the analyst denied them: disable fatima.sani and revoke MailSync Pro. These should be approved next, followed by a password and session reset and MFA re-enrolment.
- Block 198.51.100.44, 203.0.113.77 and secure-docs-auth.example; search mail for other recipients of the lure.
- Reimage the workstation, then validate: no beacon for 24 hours, no new OAuth grants, clean sign-in history.
- Rollback: re-enable the account and release the host from isolation if the investigation shows a false positive.

## **Data-protection considerations**

Personal data involved: one employee identity, her sign-in locations and mailbox access. The exfiltrated 96 MB may contain customer or personnel data, so the DPO and legal should be told now, since a notification clock may be running. Evidence access is limited to the case team; retain logs under the incident-retention policy.

## **Lessons and backlog**

- Link incidents that share an attacker IP (SOAR-0005 and SOAR-0006). New backlog item.
- Make the 30-minute approval expiry real (S2) and log model name and prompt hash for AI calls (G2).
- Keep the benign-context rule. In SOAR-0009 a blocked and quarantined attachment fell from 83 to 68, and in SOAR-0005 an approved change no longer triggers isolation.
- Trade-off to defend: SOAR-0005 stays critical (91) because a privileged admin account was sprayed from a known-bad IP, even though the lockout held.